ONE-PAGE BRIEF

Post-quantum cryptography review: seedsigner @ ada81cde050e

Client: SeedSigner — public repository (passive review) · Source: github.com/SeedSigner/seedsigner, commit `ada81cde050e` · Reviewed: 2026-11-04 19:25 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY

Level 0 of 4

no post-quantum cryptography

FINDINGS

0 Critical **2** High **2** Medium

0 Low **0** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Key establishment: 10 + 5 − 8 = 7 → **too late**

Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

High QSI-2026-12818	**Non-cryptographic generator next to key or seed generation in src/seedsigner/views/seed_views.py** preliminary What to do: Use the platform CSPRNG (secrets, os.urandom, crypto.getRandomValues, crypto/rand, SecureRandom, OsRng) or a hardware TRNG for every key...
High QSI-2026-12819	**Non-cryptographic generator next to key or seed generation in tools/mnemonic.py** preliminary What to do: Use the platform CSPRNG (secrets, os.urandom, crypto.getRandomValues, crypto/rand, SecureRandom, OsRng) or a hardware TRNG for every key...
Medium QSI-2026-12816	**Quantum-vulnerable RSA key (3072-bit) in seedsigner_pubkey.gpg** What to do: Inventory and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205), in a hybrid/ composite form where the ecosystem supports it..
Medium QSI-2026-12817	**Quantum-vulnerable ECDSA: transaction and message signing (1 file(s))** confirmed by the analyst What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains...

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium transaction and message signing	ECDSA	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...

Analyst review: 1 confirmed, 0 not applicable, 0 dismissed as false positives. (QSI review, 2026-10-29)

Static review of source code and manifests; files analysed: 76. No requests were sent to the owner's systems.

Full report, content SHA-256: `0d233bfb8d1a65a906d6c82ae8f7ee22cae7fe48eb5749141f8ef70df99894fd`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.